



Raport ekspercki

Badanie bezpieczeństwa sieci od środka

5

Wykryte urządzenia

10

Otwarte porty

10

Ustalenia wymagające działania

5

Luki w pokryciu badania

Sonda

Sonda demonstracyjna

Identyfikator badania

PROBKA-0000-0000-0000-DEMO

Data wykonania badania

2026-09-18 09:12:44

Przebieg badania

zakończone

Adres sondy w badanej sieci

192.0.2.250

Raport odebrany

2026-10-04 14:03:26 UTC

1. Podsumowanie badania

Ocena ryzyka wynikająca z całości badania.

Badanie wykazało stan wymagający pilnych działań naprawczych. W sieci zidentyfikowano jedno ustalenie o wadze krytycznej, trzy o wadze wysokiej oraz sześć o wadze średniej, co przekłada się na bezpośrednie ryzyko naruszenia poufności, dostępności i integralności ruchu. Kluczowy punkt zapalny stanowi host 192.0.2.30, na którym jednocześnie stwierdzono podatność SSL POODLE na porcie 8443, podatność na atak Slowloris na tym samym porcie oraz ekspozycję bazy MySQL i protokołu Modbus. Ostrzeżenie należy sformułować wprost: przy obecnej konfiguracji możliwe jest przechwycenie ruchu w segmencie oraz wywołanie odmowy usługi na wystawionym interfejsie HTTPS.

Część badania nie została zrealizowana, a obszarów tych nie objęto żadną oceną. Skanowanie portów urządzenia 192.0.2.40 nie powiodło się, testy sieci bezprzewodowej zostały zablokowane, wynik zatruwania rozgłoszeń nie został przekazany, a test wycieków z katalogu LDAP nie wykonał się. Pięć zidentyfikowanych luk w pokryciu oznacza, że rzeczywisty poziom ryzyka może być wyższy niż suma ustaleń przedstawionych poniżej.

2. Ustalenia według wagi

Wszystko, co badanie wykazało, zebrane w jednym miejscu i uszeregowane od najpoważniejszego. Wagi wynikają z tego, co stwierdziły testy - ustalenie, którego test nie zdołał potwierdzić, jest oceniane niżej niż potwierdzone.

1

Krytyczne

3

Wysokie

6

Średnie

0

Informacyjne

WAGA	GDZIE	USTALENIE
Krytyczne	192.0.2.30 ssl-poodle · port 8443	SSL POODLE information leak CVE-2014-3566
Wysokie	192.0.2.30 http-slowloris-check · port 8443	Slowloris DOS attack CVE-2007-6750
Wysokie	192.0.2.20 23/TCP	Telnet dostępny w sieci Protokół przesyła hasła otwartym tekstem.
Wysokie	cała sieć	Brak blokady Gratuitous ARP — ruch w sieci można przechwycić i podsłuchać.
Średnie	192.0.2.20 port 80	Panel kamery dostępny po nieszyfrowanym HTTP Wymuś HTTPS i ogranicz dostęp do sieci zarządzającej.
Średnie	192.0.2.1 port 53	Znane podatności w dnsmasq 2.80 (3 CVE, najwyższy CVSS 8.1) CVE-2021-3448, CVE-2020-25681, CVE-2020-25684 Dopasowanie po numerze wersji - wymaga potwierdzenia, czy podatny kod jest faktycznie używany.
Średnie	192.0.2.10 445/TCP	Udostępnianie plików SMB dostępny w sieci Dostęp do plików i klasyczny cel ataków w sieci lokalnej.
Średnie	192.0.2.30 3306/TCP	Baza danych MySQL dostępny w sieci Baza danych nasłuchująca w sieci.
Średnie	192.0.2.30 502/TCP	Modbus dostępny w sieci
Średnie	cała sieć	Porty przepuszczane na zewnątrz: 23, 445, 3389

Luki w pokryciu badania (5)

Poniższe testy nie dostarczyły wyniku. Tych obszarów badanie nie sprawdziło, więc nie można ich uznać ani za bezpieczne, ani za zagrożone.

- 192.0.2.40 — Skanowanie portów: test nie powiódł się na tym urządzeniu
- Sieci bezprzewodowe: test zablokowany przez zakres lub politykę badania
- Zatrutowanie rozgłoszeń — sonda nie przekazała wyniku
- Wycieki z katalogu LDAP — test nie wykonał się
- Bezpieczeństwo sieci bezprzewodowej — Nie udało się włączyć trybu monitora, więc nasłuch się nie odbył.

W najwyższej wadze zaklasyfikowano podatność SSL POODLE (CVE-2014-3566) na hostcie 192.0.2.30 w ramach usługi na porcie 8443. Mechanizm polega na wymuszeniu na kliencie degradacji szyfrowania do SSLv3 i wykorzystaniu słabości wypełnienia blokowego do odzyskania fragmentów chronionych danych. Skutkiem jest wyciek informacji z sesji, którą użytkownik uważa za szyfrowaną.

W wadze wysokiej odnotowano trzy wektory. Na tym samym porcie 8443 hosta 192.0.2.30 test http-slowloris-check wskazał stan LIKELY VULNERABLE (CVE-2007-6750) — mechanizm opiera się na utrzymywaniu wielu niedokończonych sesji HTTP, co wyczerpuje pulę połączeń serwera i prowadzi do odmowy usługi. Na hostcie 192.0.2.20 stwierdzono dostępność usługi Telnet na porcie 23/TCP, która przesyła poświadczenia otwartym tekstem, umożliwiając ich przechwycenie przez podmiot w tym samym segmencie. Niezależnie od powyższego odnotowano brak blokady Gratuitous ARP — przełącznik nie przeciwdziała przekierowaniu ruchu, w efekcie ruch w segmencie może zostać przechwycony i podsłuchany w ramach ataku typu man-in-the-middle.

Ostrzeżenia nie sformułowano dla jednego wykonanego testu pogłębionego, który zakończył się wynikiem czystym. Wobec obszarów objętych lukami w pokryciu badania nie wydaje się oceny — skanowanie portów 192.0.2.40 nie odbyło się, testy sieci bezprzewodowej zostały zablokowane przez zakres lub politykę, wynik zatrutowania rozgłoszeń nie został przekazany przez sondę, a wycieki z katalogu LDAP nie zostały przetestowane.

3. Wykryte urządzenia

Przegląd segmentu sieci i lista wszystkich urządzeń, które się w nim odezwały. Urządzenie, które odpowiedziało przy wykrywaniu, ale zamilkło przy skanowaniu portów, jest odnotowane osobno.

Test nie powiódł się na 1 urządzeniu: 192.0.2.40. Wyniki poniżej dotyczą wyłącznie urządzeń, które udało się sprawdzić.

ADRES	ADRES SPRZĘTOWY	PRODUCENT I MODEL	STAN
192.0.2.1	02:00:5e:00:53:01	Acme Networks GW-200 Linux 4.x (router)	3 otwarte porty
192.0.2.10	02:00:5e:00:53:0a	NorthStore NAS-4B Linux (NAS)	2 otwarte porty
192.0.2.20	02:00:5e:00:53:14	Visinet IP-Cam 3 Embedded Linux	2 otwarte porty
192.0.2.30	02:00:5e:00:53:1e	Generic Server Co. CentOS 7	3 otwarte porty
192.0.2.40	—	nieznany	skanowanie nieudane test przekroczył limit czasu

Wykrytych urządzeń: **5**, odpowiedziało na skanowanie portów: **4**.

Wykryto pięć urządzeń, z których cztery odpowiedziały na skanowanie portów i na czterech stwierdzono co najmniej jeden otwarty port. Zidentyfikowano router 192.0.2.1 (Acme Networks GW-200, Linux 4.x), serwer NAS 192.0.2.10 (NorthStore NAS-4B), kamerę IP 192.0.2.20 (Visinet IP-Cam 3, Embedded Linux) oraz serwer 192.0.2.30 (CentOS 7). Wszystkie cztery urządzenia są osiągalne. Skanowanie portów urządzenia 192.0.2.40 nie powiodło się — test przekroczył limit czasu, w związku z czym profil tego hosta pozostaje nieustalony, a jego stanu nie ocenia się.

4. Usługi dostępne w sieci

Sprawdzenie, co nasłuchuje na każdym wykrytym urządzeniu i w jakiej wersji. Wynik zostaje zachowany w pełnej postaci, nie w formie skrótu.

Test nie powiódł się na 1 urządzeniu: 192.0.2.40. Wyniki poniżej dotyczą wyłącznie urządzeń, które udało się sprawdzić.

URZĄDZENIE	PORT	USŁUGA	WERSJA ROZPOZNANA PRZEZ SONDĘ
192.0.2.1	53/TCP	domain	dnsmasq 2.80
192.0.2.1	80/TCP	http	lighttpd 1.4.59
192.0.2.1	443/TCP	https	lighttpd 1.4.59
192.0.2.10	445/TCP	microsoft-ds	Samba smbd 4.15.13
192.0.2.10	5000/TCP	http	Synology DSM httpd
192.0.2.20	23/TCP	telnet	nie ustalono
192.0.2.20	554/TCP	rtsp	nie ustalono
192.0.2.30	22/TCP	ssh	OpenSSH 7.4
192.0.2.30	3306/TCP	mysql	MySQL 5.7.38
192.0.2.30	8443/TCP	https	nie ustalono

Otwartych portów łącznie: 10, na 4 urządzeniach.

Na hoscie 192.0.2.1 wystawiono dnsmasq 2.80 na porcie 53/TCP oraz lighttpd 1.4.59 na portach 80/TCP i 443/TCP. Na hoscie 192.0.2.10 działa Samba smbd 4.15.13 na porcie 445/TCP oraz Synology DSM httpd na porcie 5000/TCP. Host 192.0.2.20 udostępnia telnet na porcie 23/TCP i rtsp na porcie 554/TCP. Na hoscie 192.0.2.30 wystawiono OpenSSH 7.4 na porcie 22/TCP, MySQL 5.7.38 na porcie 3306/TCP oraz usługę HTTPS na porcie 8443/TCP.

Ryzyko koncentruje się na usługach przesyłających dane w postaci jawnej oraz na interfejsach bazodanowych i administracyjnych nasłuchujących w sieci. Protokół Telnet w połączeniu z RTSP na urządzeniu 192.0.2.20 tworzy ścieżkę do przechwycenia zarówno poświadczeń, jak i strumienia wideo. Baza MySQL na hoscie 192.0.2.30 jest nasłuchująca w sieci, co poszerza powierzchnię ataku poza warstwę aplikacyjną.

5. Pogłębione testy podatności

Testy uruchamiane przeciwko znalezionym usługom. Ustalenie oznaczone jako wymagające uwagi to takie, które nie zakończyło się zwykłym „nic nie znaleziono”.

URZĄDZENIE	TEST	USTALENIE
192.0.2.30	ssl-poodle	VULNERABLE: SSL POODLE information leak State: VULNERABLE IDs: CVE:CVE-2014-3566
192.0.2.30	http-slowloris-check	VULNERABLE: Slowloris DOS attack State: LIKELY VULNERABLE IDs: CVE:CVE-2007-6750

Ustaień łącznie: **3**, w tym wymagających uwagi: **2**, pozostałe 1 zakończyło się wynikiem czystym.

Pogłębione testy uruchomiono przeciwko zidentyfikowanym usługom; trzy z nich dały ustalenia, a jeden zakończył się wynikiem czystym. Na hoscie 192.0.2.30 test ssl-poodle zwrócił stan VULNERABLE (CVE-2014-3566), co potwierdza możliwość wycieku informacji przez SSLv3. Na tym samym hoscie test http-slowloris-check zwrócił stan LIKELY VULNERABLE (CVE-2007-6750), wskazując na podatność na atak odmowy usługi. Pozostały wykonany test pogłębiony nie ujawnił podatności.

W ramach korelacji wersji z bazą CVE odnotowano dla dnsmasq 2.80 na hoscie 192.0.2.1 trzy znane podatności (CVE-2021-3448, CVE-2020-25681, CVE-2020-25684) o najwyższym wskaźniku CVSS 8.1. Dopasowanie oparto na numerze wersji i wymaga potwierdzenia, czy podatny kod jest faktycznie używany.

6. Ekspozycja i poświadczenia

Udziały plików dostępne bez uwierzytelnienia, ruch przestarzałych mechanizmów rozwiązywania nazw, pozostawione domyślne dane logowania oraz informacje wyciekające z katalogu firmowego do klientów anonimowych.

BADANY OBSZAR	WYNIK
Anonimowe sesje i udziały SMB	stan prawidłowy — nie stwierdzono podatności
Zatrutowanie rozgłoszeń	brak danych Sonda nie przekazała wyniku tego testu.
Skanowanie szablonami znanych podatności	stan prawidłowy — nie stwierdzono podatności
Domyślne poświadczenia	stan prawidłowy — nie stwierdzono podatności
Wycieki z katalogu LDAP	test nie wykonał się Test nie został uruchomiony, więc ten obszar pozostaje niesprawdzony.
Ryzyka infrastrukturalne	stan prawidłowy — nie stwierdzono podatności

Jeden moduł badania nie wykonał się poprawnie. Wyniku tych testów nie należy czytać jako „nic nie znaleziono” - one się nie odbyły.

W zakresie anonimowych sesji i udziałów SMB nie stwierdzono podatności. Skanowanie szablonami znanych podatności nie wykazało podatności. W testach domyślnych poświadczeń nie stwierdzono podatności. W obszarze ryzyk infrastrukturalnych nie stwierdzono podatności.

Test wycieków z katalogu LDAP nie wykonał się — obszar ten nie został sprawdzony. Wynik zatrutowania rozgłoszeń nie został przekazany przez sondę, w związku z czym nie jest dostępna żadna ocena tego wektora. Uzyskane wyniki czyste dotyczą wyłącznie testów, które faktycznie się odbyły.

7. Protokoły przemysłowe ICS i OT

Punkty końcowe sterowania przemysłowego, takie jak CODESYS Runtime, EtherNet/IP czy IEC 60870-5-104, które zwykle nie mają czego szukać w sieci biurowej.

URZĄDZENIE	PORT	PROTOKÓŁ	STAN	OCENA SONDY
192.0.2.30	502/TCP	Modbus	open	WARNING

Punktów końcowych ICS/OT: 1. Stan open|filtered oznacza, że sonda nie mogła rozstrzygnąć, czy port jest otwarty, czy odfiltrowany.

Zidentyfikowano jeden punkt końcowy protokołów przemysłowych: na hostie 192.0.2.30 wystawiono protokół Modbus na porcie 502/TCP w stanie open, z oceną sondy WARNING. Protokół ten nie zapewnia uwierzytelniania ani szyfrowania, a jego obecność na serwerze ogólnego przeznaczenia działającym w segmencie biurowym oznacza, że punkt końcowy OT nie podlega izolacji od pozostałej części sieci. Urządzenie to łączy jednocześnie rolę hosta z wystawioną bazą danych, interfejsem HTTPS i usługą SSH, co poszerza wektor ataku na sterowanie procesem przemysłowym.

8. Diagnostyka sieci

Kondycja i konfiguracja sieci: opóźnienia, DNS, podatności na podsłuch i podszywanie się, zabezpieczenie portu dostępowego, ruch wychodzący oraz przepustowość. Poniżej znajdują się wyłącznie te testy, których wynik sonda przekazała.

Opóźnienia w sieci

Status	ok
Najniższe	0.4 ms
Średnie	0.8 ms
Najwyższe	1.9 ms

Kondycja DNS

Status	ok
Odpytany serwer	192.0.2.1
Czas odpowiedzi	12 ms

Podatność na podsłuch (MITM)

Status	ok
▲ Brak blokady Gratuitous ARP — ruch w sieci można przechwycić i podsłuchać.	
Assessment	Przełącznik nie blokuje Gratuitous ARP - ruch w segmencie można przekierować.

Filtrowanie ruchu wychodzącego

Status	ok
Porty przepuszczane na zewnątrz	▲ 23, 445, 3389

Bezpieczeństwo sieci bezprzewodowej

Status	blocked
Reason	foreign_block
▲ Nie udało się włączyć trybu monitora, więc nasłuch się nie odbył.	
Przechwycone ramki EAPOL	0

Przepustowość łącza

Opóźnienie (ping)	18.4 ms
Pobieranie	184.2 Mbit/s
Wysyłanie	41.7 Mbit/s

Najbardziej obciążające urządzenia

ADRES	PAKIETY	RUCH ŁĄCZNIE	WYSŁANE	ODEBRANE
192.0.2.10	182340	136,3 MB	90000 pk · 76,3 MB	92340 pk · 60,0 MB
192.0.2.1	90120	17,5 MB	45000 pk · 8,6 MB	45120 pk · 9,0 MB

Opóźnienia w sieci pozostają na poziomie niskim: najniższe 0,4 ms, średnie 0,8 ms, najwyższe 1,9 ms. Kondycja DNS jest prawidłowa — serwer 192.0.2.1 odpowiada w czasie 12 ms. Przepustowość łącza wynosi 184,2 Mbit/s dla pobierania i 41,7 Mbit/s dla wysyłania przy opóźnieniu ping 18,4 ms. Największe obciążenie generują hosty 192.0.2.10 (182340 pakietów, 136,3 MB ruchu) oraz 192.0.2.1 (90120 pakietów, 17,5 MB ruchu).

W teście podatności na podsłuch odnotowano brak blokady Gratuitous ARP — przełącznik nie przeciwdziała przekierowaniu ruchu, co umożliwia podsłuch i przekierowanie ruchu w segmencie. W teście filtrowania ruchu wychodzącego stwierdzono przepuszczanie na zewnątrz portów 23, 445 i 3389, co pozwala na wychodzącą komunikację tymi kanałami. Bezpieczeństwo sieci bezprzewodowej zostało zablokowane — nie udało się włączyć trybu monitora i nasłuch się nie odbył; przechwycono 0 ramek EAPOL, co przy nieprzeprowadzonym nasłuchu nie stanowi wyniku oceny.

9. Plan naprawy

Działania wynikające wyłącznie z ustaleń tego badania, uszeregowane od najpilniejszego.

1. Wyłączenie obsługi SSLv3 i usunięcie podatności SSL POODLE na hostie 192.0.2.30, port 8443.
2. Wdrożenie ochrony przed atakiem Slowloris na hostie 192.0.2.30, port 8443, poprzez limity czasu i liczby równoległych połączeń.
3. Wyłączenie usługi Telnet na hostie 192.0.2.20, port 23/TCP, i zastąpienie jej protokołem szyfrowanym.
4. Wdrożenie blokady Gratuitous ARP oraz mechanizmów Dynamic ARP Inspection w segmencie sieci.
5. Ograniczenie filtrowania ruchu wychodzącego — zablokowanie portów 23, 445 i 3389 na granicy sieci.
6. Wymuszenie HTTPS na panelu kamery 192.0.2.20 i ograniczenie dostępu do sieci zarządzającej.
7. Aktualizacja dnsmasq 2.80 na hostie 192.0.2.1 oraz potwierdzenie wykorzystania podatnego kodu.
8. Ograniczenie dostępu do usługi SMB na hostie 192.0.2.10, port 445/TCP, do niezbędnych adresów.
9. Ograniczenie ekspozycji bazy MySQL 5.7.38 na hostie 192.0.2.30, port 3306/TCP, do sieci zarządzającej.
10. Izolacja protokołu Modbus na hostie 192.0.2.30, port 502/TCP, w wydzielonym segmencie ICS/OT.
11. Wykonanie testów, które się nie odbyły: skanowania portów 192.0.2.40, wycieków z katalogu LDAP, zatruwania rozgłoszeń oraz nasłuchu sieci bezprzewodowej.

Ponowne przeprowadzenie audytu weryfikującego przy pomocy sprzętowego analizatora w celu technicznego potwierdzenia skuteczności wdrożonych zabezpieczeń.